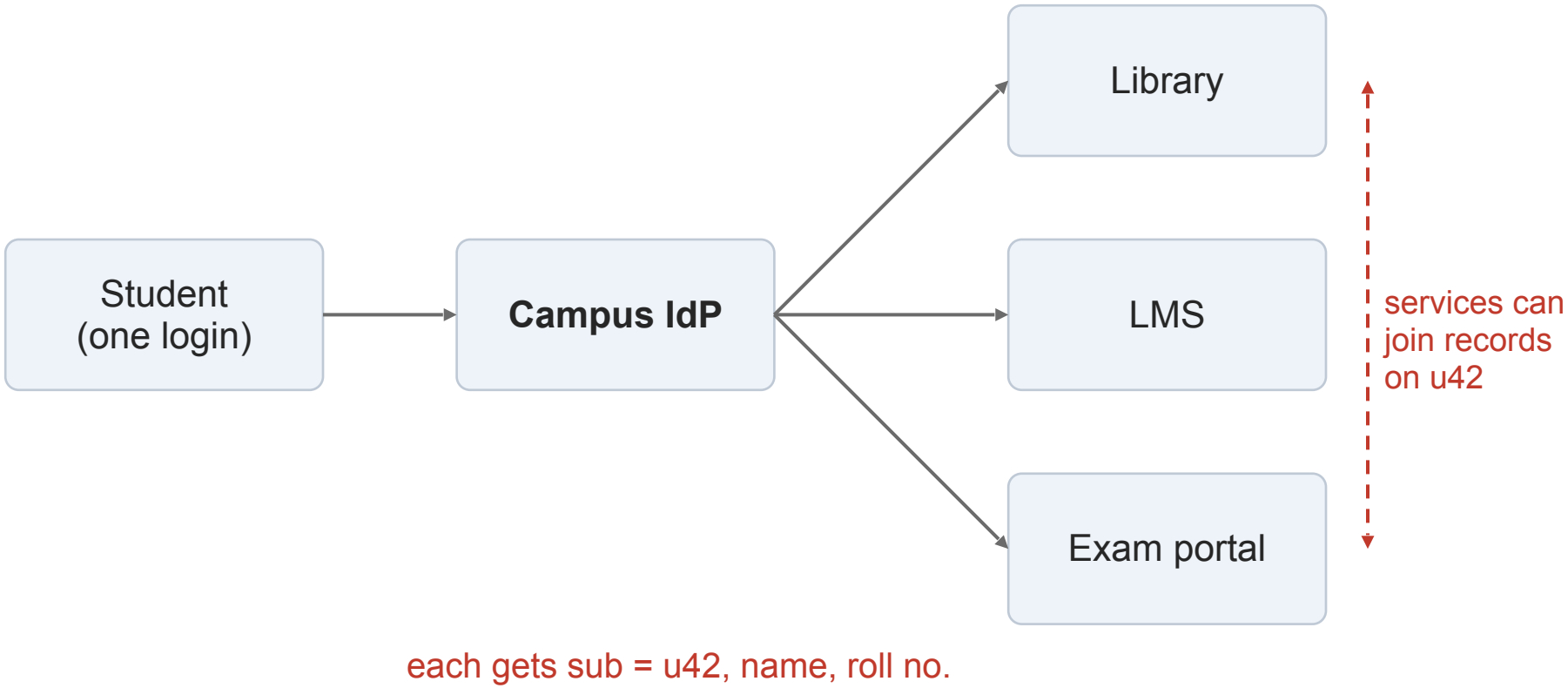
TrustTrail

Accountable, purpose-bound data release for campus single sign-on

Vijender Yadav (23BCS132) · Ansh Hardaha (23BCS016) · Sourabh (23BEC055)
Guide: Malay Kumar
B.Tech 7th semester project review · IIIT Dharwad · November 2026

Follow-up to Werner, Westphall & Westphall, “Cloud identity management: A survey on privacy strategies,” Computer Networks, 2017

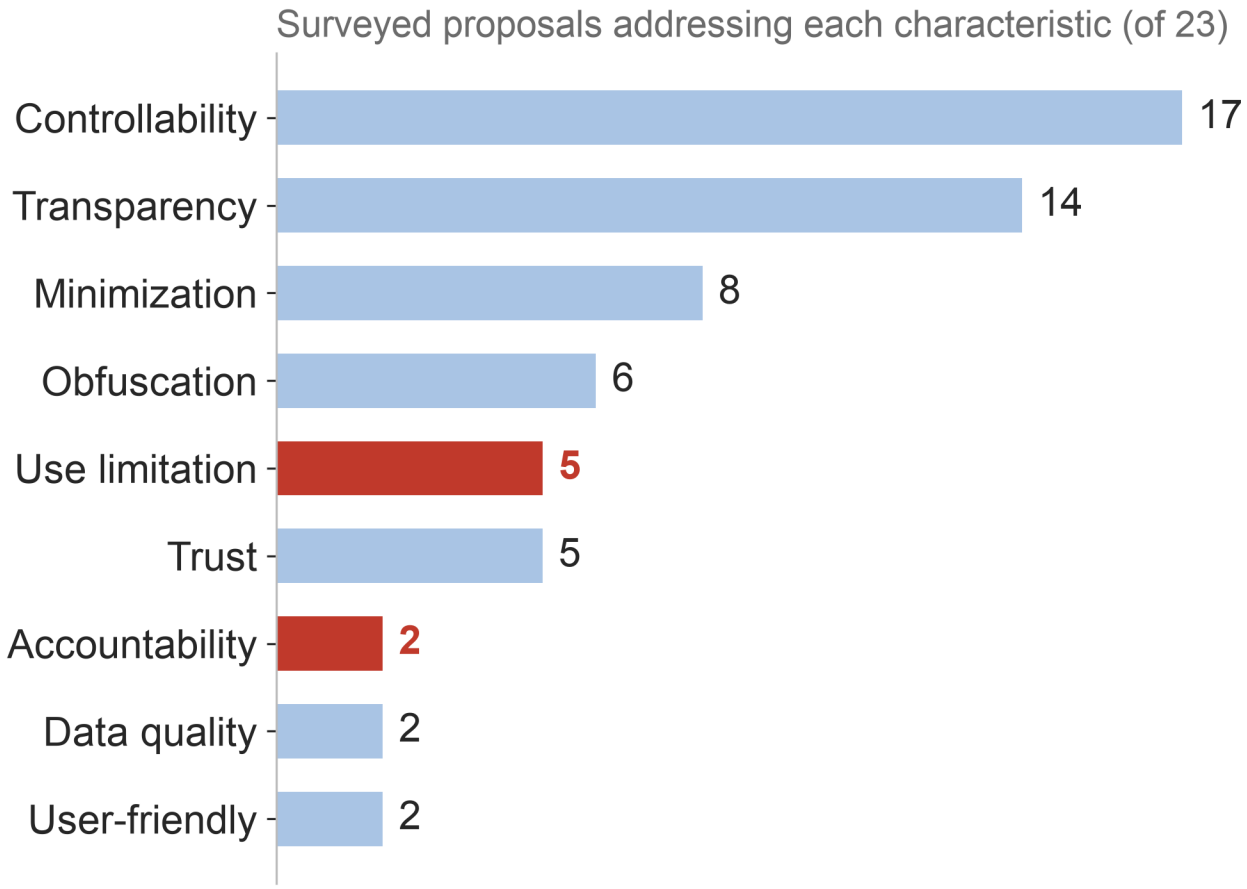
Campus SSO gives every service the same ID and personal data, and leaves no record



- **Over-release:** the library gets your name and roll number
- **Linkable:** one ID lets services join their data
- **No record:** nobody can see who got what, why, or until when

GDPR Art. 5 and India's DPDP Act 2023 require purpose limitation, minimisation and accountability

Werner et al. (2017) show accountability and use limitation are among the least-covered privacy goals



- **Accountability:** 2 of 23 proposals
- **Use limitation:** 5 of 23 proposals
- **Authors' own 4 follow-up works:** 0 for both
- Survey also names “ensure the implementation of policies” as an open challenge

Source: Werner, Westphall & Westphall, Computer Networks 122 (2017), Tables 2–3 (counts from the survey's own marks)

We set out to answer five questions

RQ1 Can each service get only its agreed attributes, without being able to link students across services?

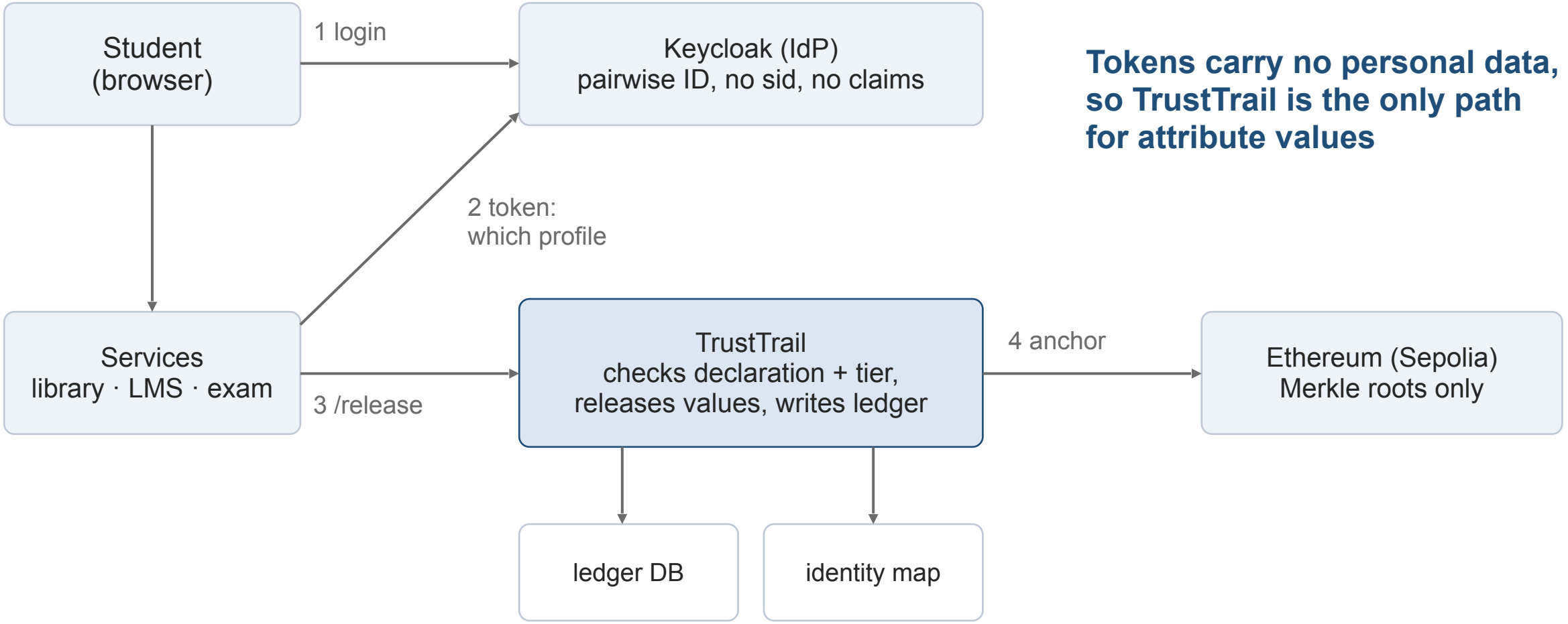
RQ2 Can every release be bound to a purpose and deletion date the service has signed?

RQ3 Can the release record be tamper-evident, even against the operator, without personal data on a blockchain?

RQ4 Can observed rule-breaking automatically reduce what a service receives?

RQ5 What does this cost in login time and blockchain fees?

Keycloak decides which profile a service may get; TrustTrail decides what it contains



Tokens carry no personal data, so TrustTrail is the only path for attribute values

Each service gets a different pseudonym, but only after we removed Keycloak's shared session ID

Profile	Released	Cap of tier
anonymous	affiliation	blocked
pseudonym	+ pseudonym (sub)	untrusted
partial	+ department, programme, year	semi-trusted
total	+ name, email, roll no.	fully trusted

Same student, three services:

```
library   f266e8cf-…
LMS       4336de76-…
exam      158b3330-…
```

Finding

Keycloak 26 puts the same session ID (sid) into every service's token in one login session.

Two services comparing sid could link the student's pseudonyms.

Our 72-line Keycloak mapper removes it; a browser-level test checks it.

A service must sign its purpose and deletion date before it receives any data

Purpose declaration (signed by the LMS, ES256)

```
{ "client_id": "lms",
  "attributes": ["sub", "affiliation",
     "department", "program", "year"],
  "purpose": "Enrol you in the courses of
     your department, program and year.",
  "retention_until": "2027-05-09",
  "nonce": "…", "iat": …, "exp": … }
```

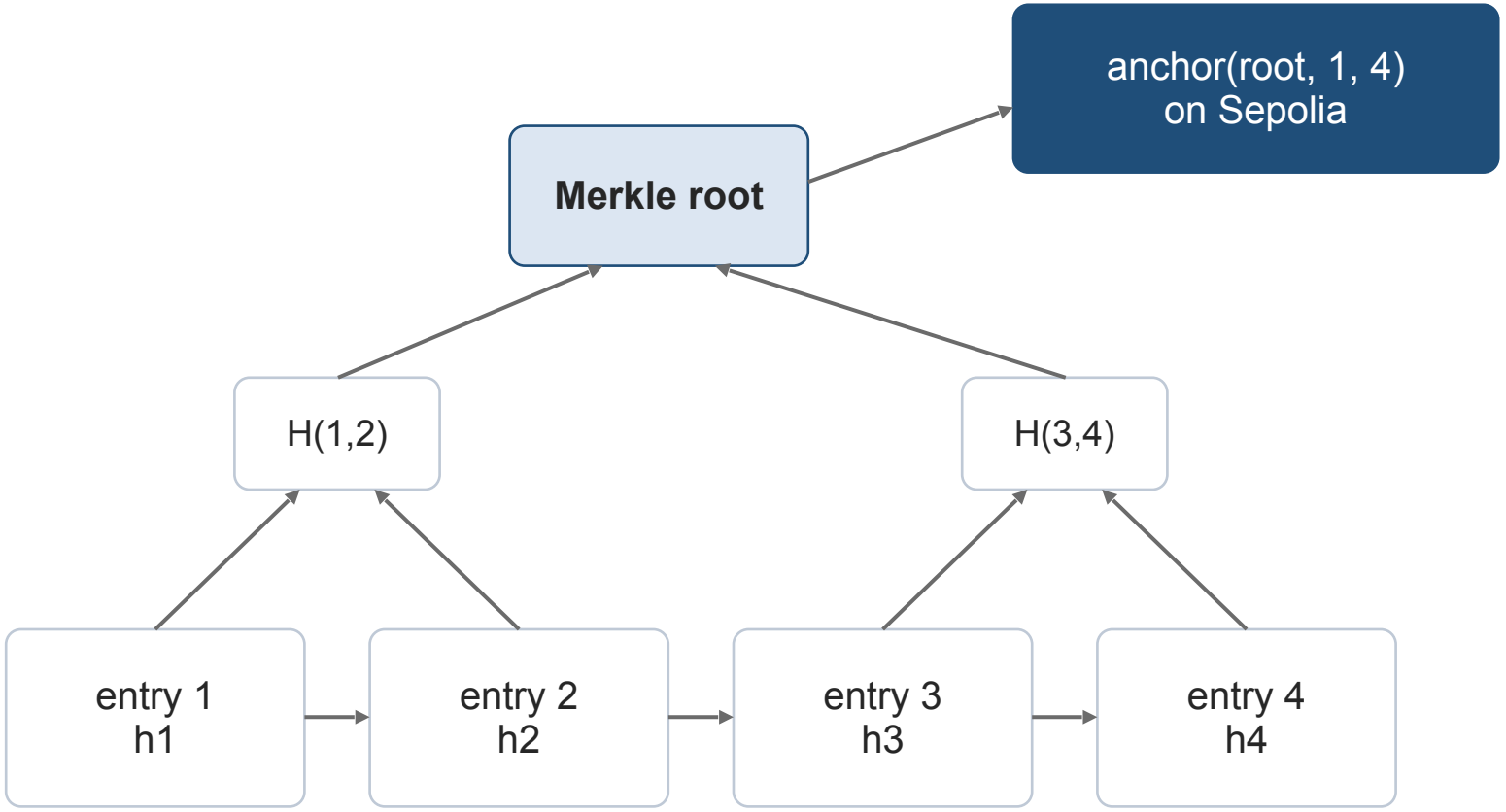
TrustTrail refuses and records:

- **Rule 1** · attribute not in the declaration
- **Rule 2** · request after the deletion date
- **Rule 3** · more than its tier allows

Every release returns a receipt signed by TrustTrail, bound to the declaration's hash

Signature formats: JWS (RFC 7515), key IDs: JWK thumbprint (RFC 7638)

Every release and rule break is hash-chained and anchored on Ethereum

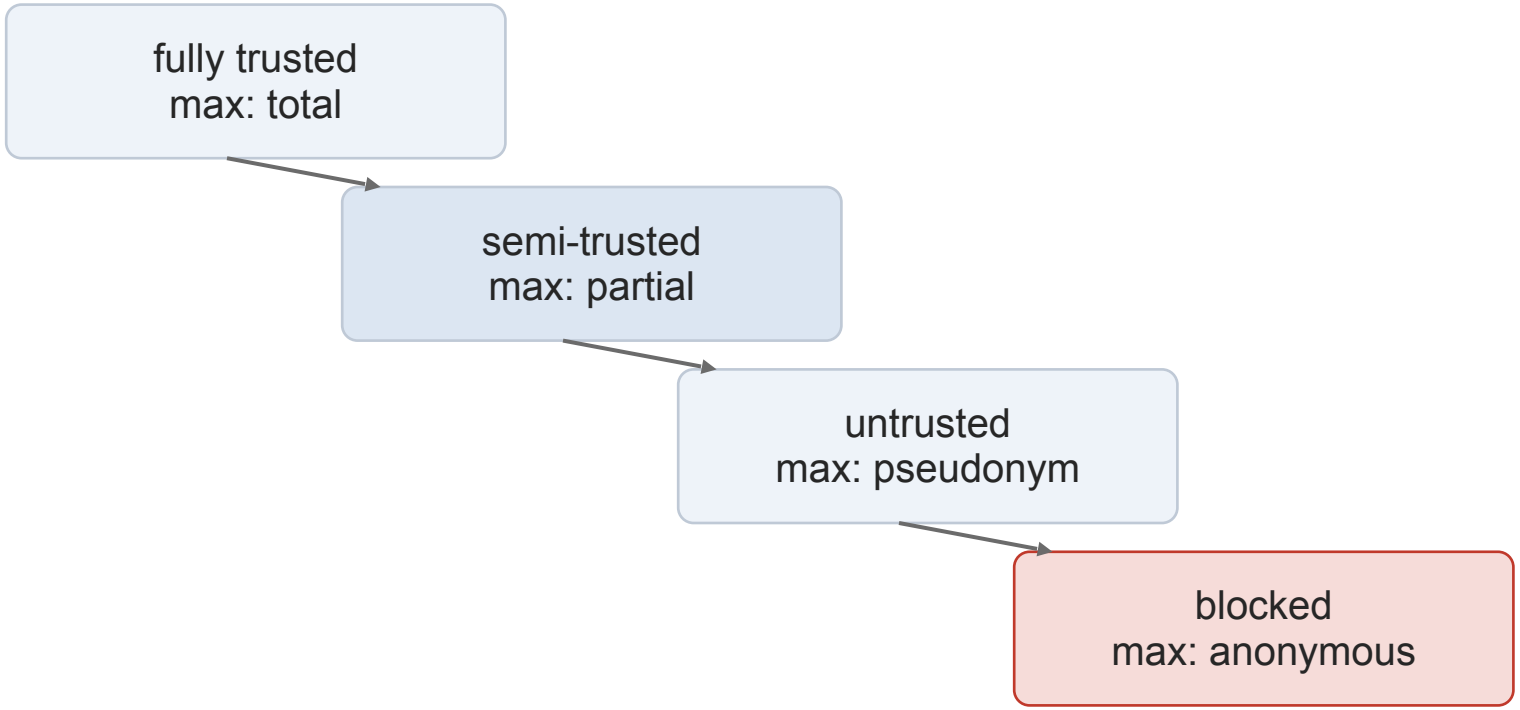


each entry contains the previous entry's hash

- Only a 32-byte root goes on chain, never personal data
- Contract accepts only contiguous batches, so a cut-off ledger is visible
- Students verify their receipt against the chain without TrustTrail

Merkle hashing as in Certificate Transparency (RFC 6962); hash-chained logs: Schneier & Kelsey (1999)

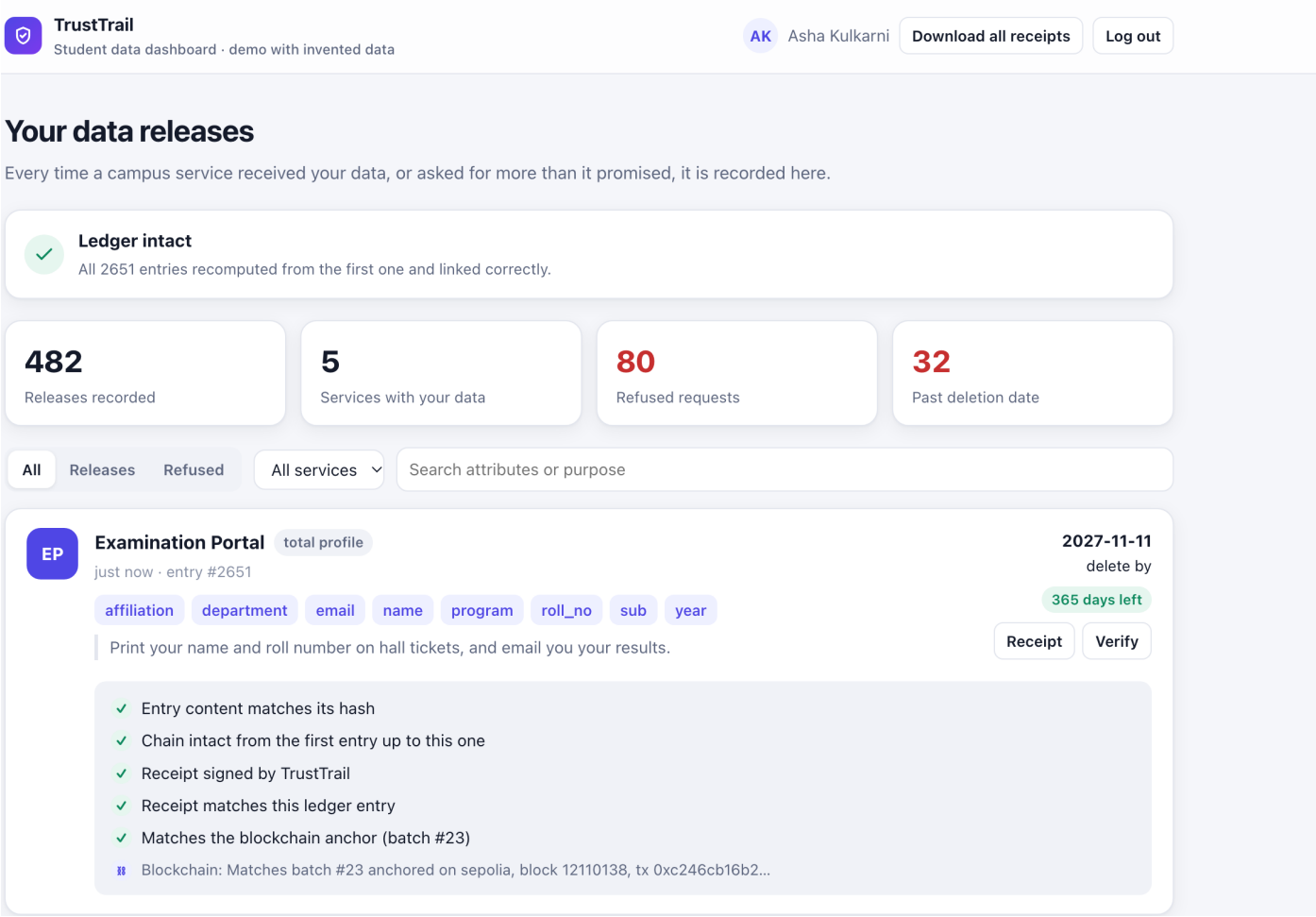
Breaking a rule automatically lowers what a service can receive



- Each violation costs 25 points = one tier down
- Keycloak stops granting the higher profiles; tokens already issued are capped at release
- Requests within the original agreement are not counted again, so one mistake does not snowball

Campus Deals asked for e-mail it never declared:
semi-trusted → untrusted → blocked in two violations

Students can see, verify and download proof of every release



- Every release and refused request, with purpose and delete-by date
- Verify: hash, chain, signed receipt, and the Sepolia anchor
- Download signed receipts to check later without TrustTrail

Real screenshot of our running system (invented student data)

Live demo: from login to a release verified on the public chain

1. Open the Learning System and see its signed promise
2. Log in once with university SSO
3. Compare: Keycloak token (no personal data) vs. TrustTrail release + receipt
4. Open the dashboard and press Verify
5. Show refused requests and the service's lowered tier

URLs

`lms.localhost:8002`
`localhost:8000/dashboard`

If the demo fails:
backup screenshots in Appendix A1–A3

Built on Keycloak, FastAPI and Solidity, with 151 tests, and deployed on Sepolia

151

Python tests
(+6 contract tests)

~5,800

lines of code

7

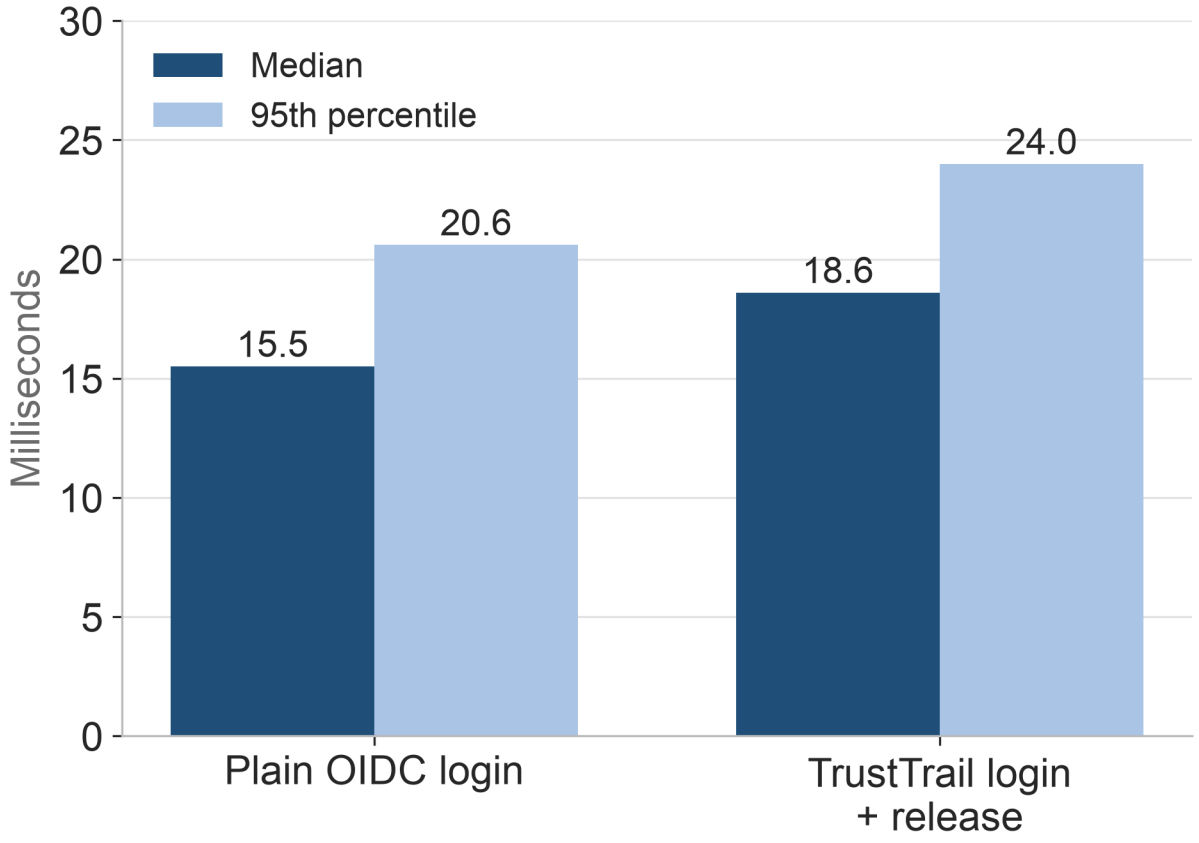
Docker containers

6

build phases

Layer	Technology
Identity provider	Keycloak 26.8.1 + custom Java mapper
Release service	Python 3.12, FastAPI, SQLite, PyJWT (ES256 / RS256)
Blockchain	Solidity 0.8.28 contract, Hardhat 3, web3.py; Sepolia test network
Code	github.com/desmond009/Trust-Trail

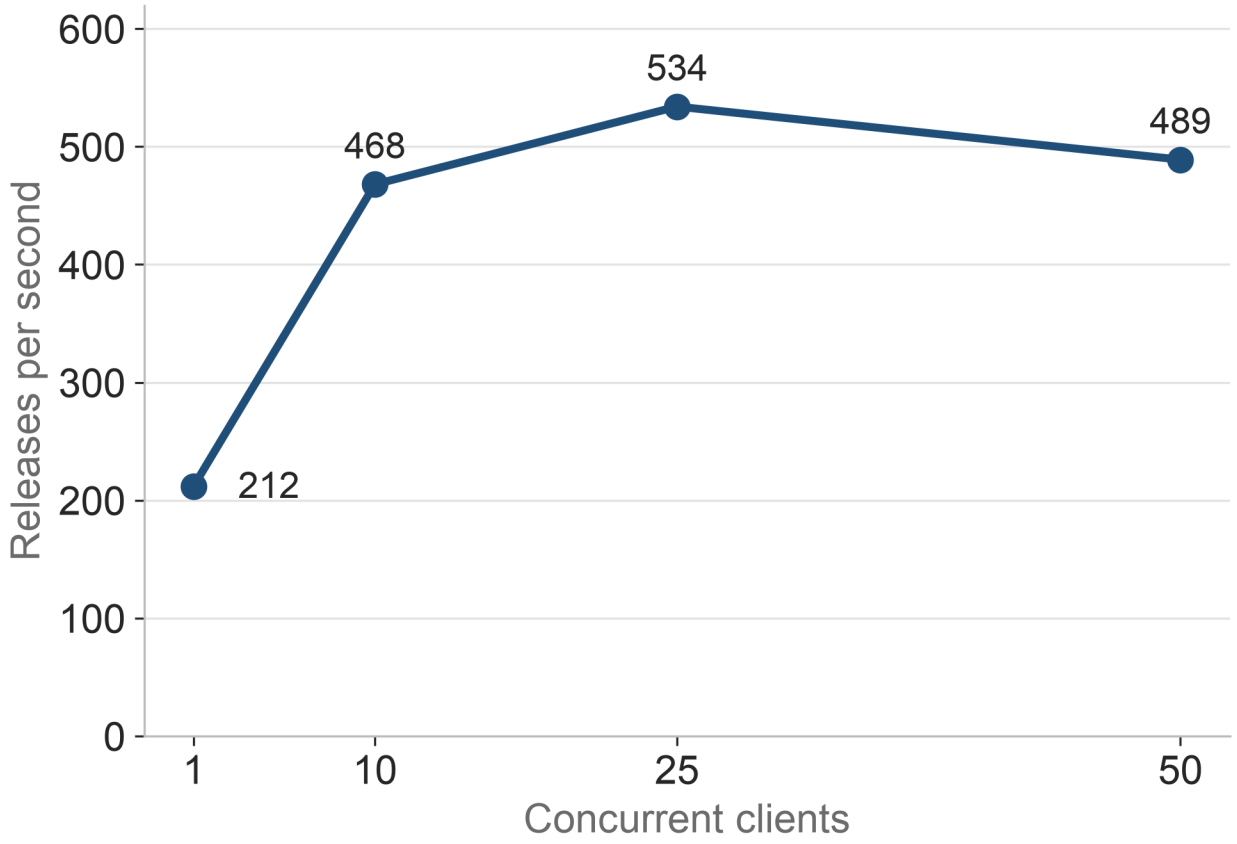
The privacy layer adds about 3 ms per login, mostly one Keycloak call and one commit



- **+3.2 ms median** (95% CI 3.0–3.4), 200 runs each
- Inside /release (1.2 ms): Keycloak fetch 0.50 ms, database commit 0.48 ms
- All privacy checks together: under 0.04 ms

One laptop, all containers local, password grant; the ~21% relative figure is against a 15 ms loopback login

One server process handles about 500 releases per second before requests queue



- Median latency: 2 ms (1 client) → 90 ms (50 clients)
- 0 errors in 1,180 calls; hash chain intact afterwards
- **Campus estimate:** 10,000 students × 5 services in 10 min ≈ 83/s, a sixth of capacity

All six tamper attacks and 45 scripted violations were detected as designed

Attack (5 runs each)	Hash chain	Receipts*	Sepolia anchor
A. edit entry, keep hash	5/5	5/5	5/5
B. edit entry, fix hash	5/5	5/5	5/5
C. delete entry	5/5	5/5	5/5
D. rewrite all later hashes	0/5	5/5	5/5
E. cut off the tail	0/5	5/5	5/5
F. edit entry after last anchor	0/5	5/5	0/5

* assumes the affected student kept the receipt

- Every attack caught by at least one check, on local chain and Sepolia
- **Violations:** 45/45 recorded with the right rule; 0 false positives in 90 honest releases
- Conformance tests: we wrote the attacks and expected outcomes

Anchoring costs a constant 254,408 gas per batch on Sepolia, whatever its size

Operation	Entries	Gas on Sepolia
Deploy contract	–	2,411,192
First anchor	943	349,631
Later anchors	13, 14, 16	**254,408 each**

- One 32-byte root per batch, so cost does not grow with entries
- ≈ 0.00025 ETH per batch at 1 gwei; no transaction when nothing is new
- Entry → anchor delay: median 25 s with a 30 s interval; inclusion in 6–10 s

Contract: 0x3415e1C6B20E184EA493007A56589Cebf2074BC8 (Sepolia), 10 Nov 2026. Fees are estimates for a priced network; Sepolia gas was near zero.

TrustTrail gives evidence, not enforcement, after data leaves

Limits

- Cannot prove a service deleted data
- Operator decides what is written; anchors protect only anchored history
- Released attributes (department, year) can still link students
- Trust weights are heuristic; tests on one laptop

Next steps

- Usability study (designed, not yet run; ethics approval first)
- Ledger retention and erasure (DPDP Act s. 8(7), 12)
- Main network or witness cosigning
- Student choice per attribute at release

Conclusions: accountable data release is practical on a standard identity provider

RQ1 Different pseudonym per service, no shared session ID, only profile attributes

RQ2 No release without a service-signed purpose and deletion date

RQ3 Anchored history is tamper-evident on a public chain, even against the operator

RQ4 Violations lower the tier automatically, with no false positives in our tests

RQ5 ~3 ms per login, ~500 releases/s, 254,408 gas per batch

github.com/desmond009/Trust-Trail

Vijender Yadav · Ansh Hardaha · Sourabh
IIIT Dharwad

Thank you — questions welcome

References

J. Werner, C. M. Westphall, C. B. Westphall, “Cloud identity management: A survey on privacy strategies,” Computer Networks, vol. 122, pp. 29–42, 2017.

N. Sakimura et al., “OpenID Connect Core 1.0,” OpenID Foundation (pairwise identifiers, Sec. 8).

M. Jones, J. Bradley, N. Sakimura, “JSON Web Signature (JWS),” RFC 7515, 2015; M. Jones, N. Sakimura, “JWK Thumbprint,” RFC 7638, 2015.

B. Laurie, A. Langley, E. Kasper, “Certificate Transparency,” RFC 6962, 2013.

B. Schneier, J. Kelsey, “Secure audit logs to support computer forensics,” ACM TISSEC, vol. 2, no. 2, 1999.

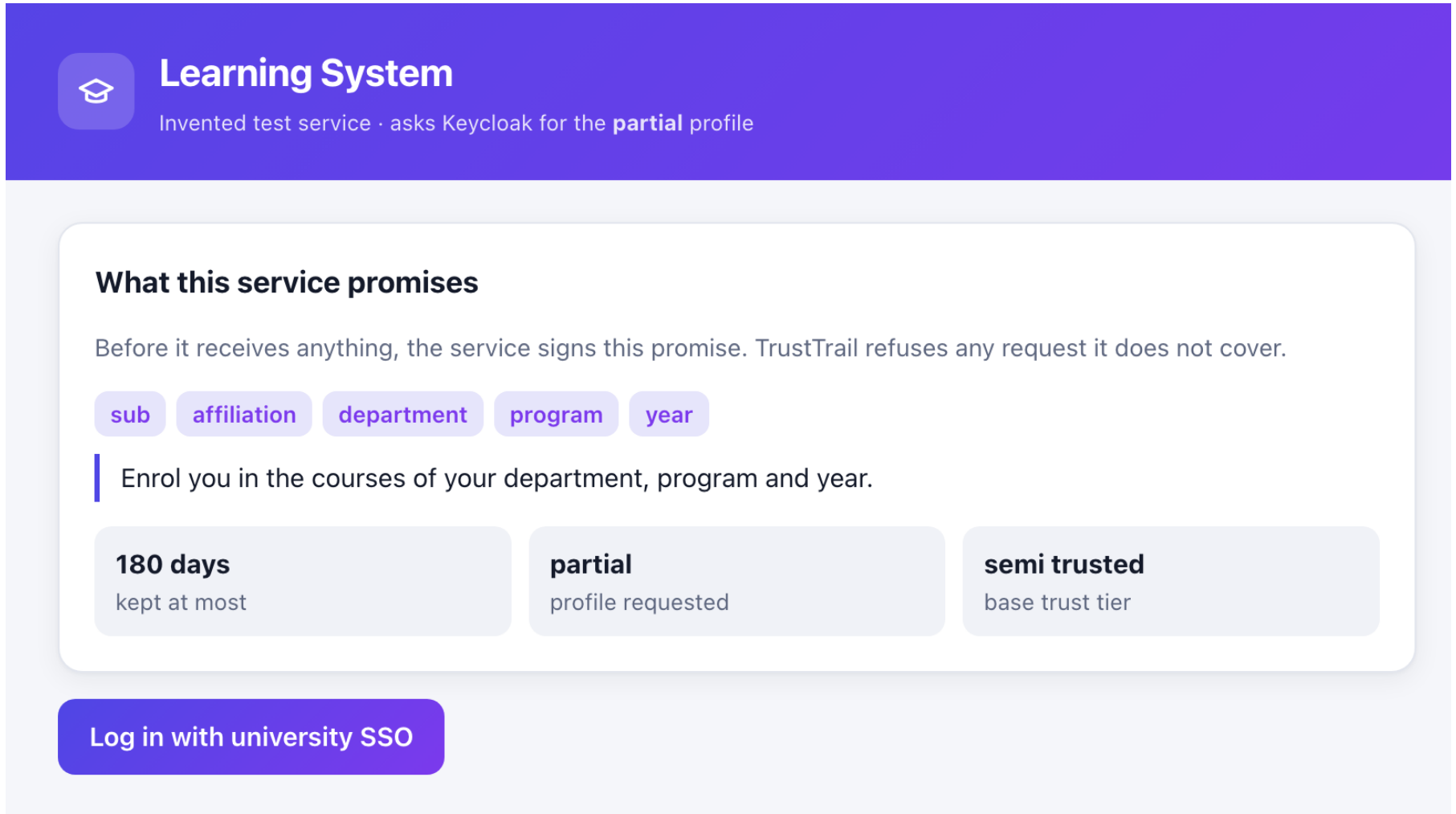
S. A. Crosby, D. S. Wallach, “Efficient data structures for tamper-evident logging,” USENIX Security, 2009.

M. S. Ferdous, R. Poet, “Managing dynamic identity federations using SAML,” J. Theor. Appl. Electron. Commer. Res., 2015.

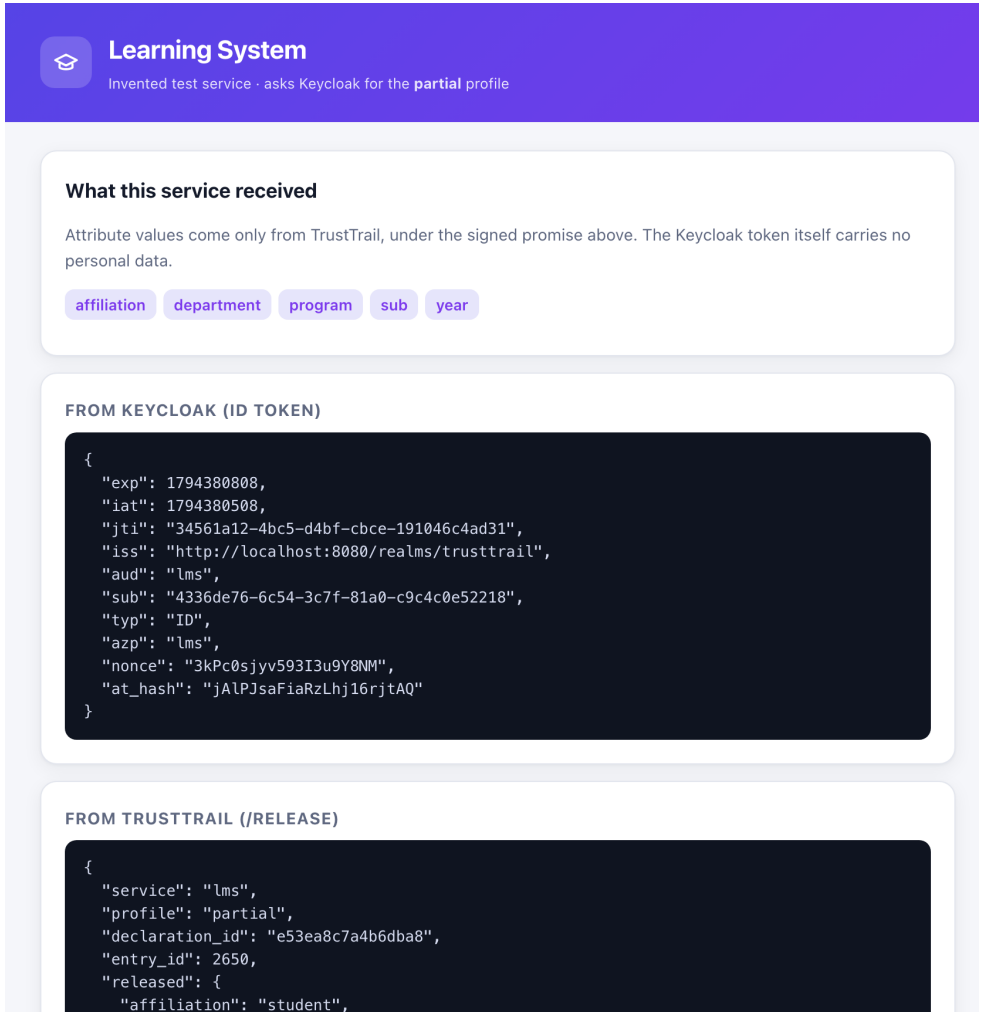
Regulation (EU) 2016/679 (GDPR); The Digital Personal Data Protection Act, 2023 (India).

Full bibliography (69 references): TrustTrail paper, github.com/desmond009/Trust-Trail

A1 · Before login, the Learning System shows the promise it has signed



A2 · After login, attribute values come only from TrustTrail; the Keycloak token has none



A3 · Refused requests appear on the dashboard and lower the service's trust

